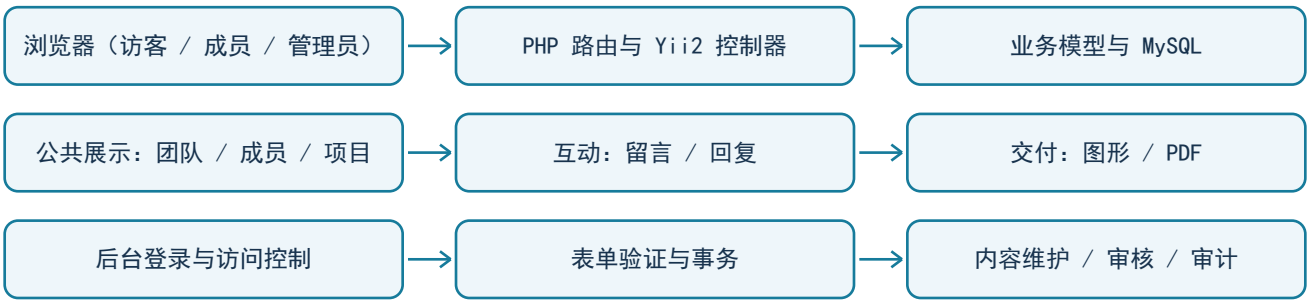
星河工坊 · 设计文档

数据库 / 模块 / 流程 / 安全边界

版本：1.0 / 2026-10-19 / 成员编号 DEMO01、DEMO02、DEMO03 均为待替换演示占位编号。

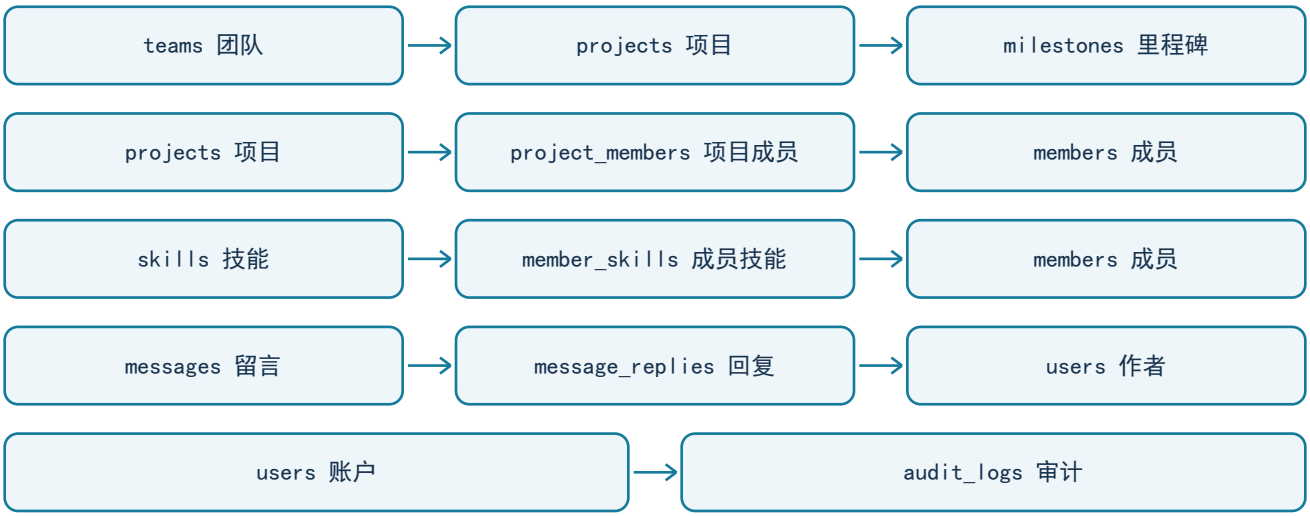
1. 总体架构与模块图

采用 PHP + Yii2 + MySQL/InnoDB 单体结构。公共站点与后台是同一个业务系统的两个入口，不引入独立前端服务或额外消息队列。数据库是业务事实的唯一来源，PDF 是构建产物。



模块责任：控制器处理请求、认证和响应；模型表达字段与业务约束；视图输出经过转义的文本；安装与运维脚本负责数据库生命周期。入口层不直接拼接用户数据进入 SQL。

2. 数据模型与关系图



关系图展示连接关系，不意味着所有箭头方向都是父子方向。项目属于团队，一项目有多个里程碑；成员与项目、成员与技能均是多对多；一留言有多条回复；回复与动态分别引用账户作者。users.member_id 可空且唯一，与成员构成可选一对一。成员是此单团队站点的全局名录，不通过不存在的 members.team_id 关联团队。

设计原则：实体身份、展示资料与登录权限分离；访客提交与公开发布是不同状态。submissions 保存下载元数据；audit_logs 保存操作轨迹；login_attempts 保存散列后的访问来源和时间，支撑登录限速。14 张表中没有为凑数增加标签功能。

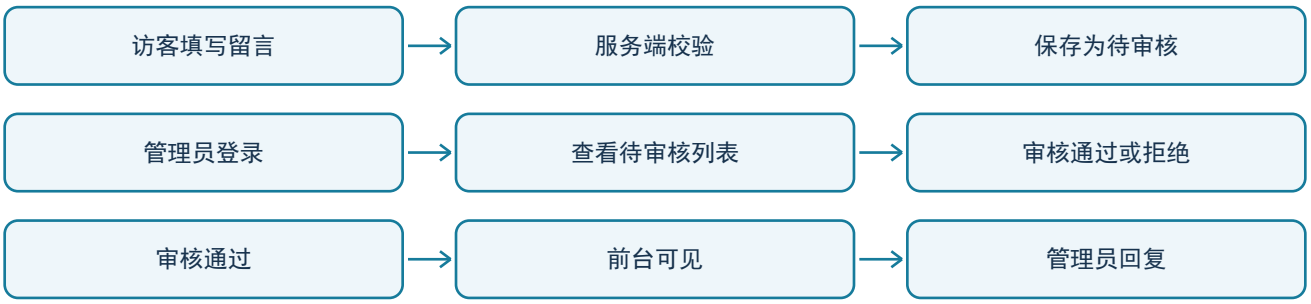
关系、基数与删除语义

父实体	子实体 / 基数	删除语义
teams	projects；一对多	RESTRICT，仍有项目时禁止删除团队。
members / skills	member_skills；多对多中间表	CASCADE，删除实体时移除关联。
members / projects	project_members；多对多中间表	CASCADE，删除实体时移除关联。
members	users；可选一对一	SET NULL，保留账户身份。
projects	updates；可选一对多	SET NULL，保留动态文本。
projects	milestones；一对多	CASCADE，里程碑随项目删除。
messages	message_replies；一对多	CASCADE，回复随留言删除。
users	updates / message_replies；一对多	RESTRICT，有作者内容时不允许删除账户。
users	audit_logs；可选一对多	SET NULL，保留审计事件。

字段业务含义与状态

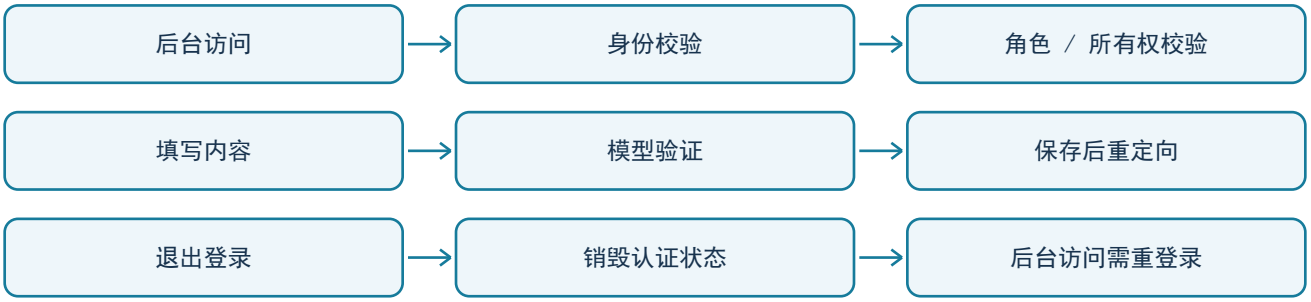
字段组	取值与含义	业务约束
projects.status / progress	planning 规划、active 进行、completed 完成；进度 0..100	published 独立控制公开与否；不能从完成状态推断公开。
updates.published / published_at	布尔发布标志与发布时间	动态关联未公开项目时仍不在前台泄漏。
messages.status	pending 待审核、approved 通过、rejected 拒绝	公共查询只取 approved，联系方式不公开。
member_skills.level	技能等级 1..5	复合主键防止同一成员重复绑定同一技能。
users.role / enabled	admin 管理员、member 成员；enabled 控制启用	password_hash 是哈希，不是明文；member_id 为档案关联。
submissions.file_name	data/team 下的 PDF 文件名	下载须校验真实路径留在目录内，拒绝路径穿越。
login_attempts.ip_hash	来源地址散列	限速用途，不保存可读 IP；不是成员或内容实体。

3. 留言审核流程图



输入非法：返回表单错误，不创建记录。未审核：只给提交者确认提示，不向所有访客展示。审核失败或未授权：保留原状态。回复必须引用已存在的留言，数据库负责拒绝悬空引用。

4. 发布与身份流程



保存后重定向（Post/Redirect/Get，PRG）避免浏览器刷新重复提交。身份认证与权限授权分别检查；后台 URL 即使被猜中，也不能绕过访问控制。更新对象不存在返回明确错误，不静默创建新对象。

5. 一致性与兼容性

外键（Foreign Key）和唯一约束（Unique Constraint）承担可执行的数据不变量（Invariant）。涉及多张关联表的写入应置于事务（Transaction）中，全部成功才提交。关联数据删除规则见下列 SQL 约束行。

内容使用 utf8mb4 支持中文和表情；默认值与空值的含义不得混淆。时间字段记录内容生命周期；公共排序应包含稳定主键，避免同一时间记录顺序不确定。

保留已有 setup.py、scripts/dev.py 与数据路径契约；正常停止保留卷，恢复导入必须显式确认。不得将安装脚本用于每次启动清空已有数据。

数据库字典：14 张业务表

以下逐字段定义直接读取 data/schema.sql，data/install.sql 为同结构的实际数据库导出。NULL、默认值、唯一键及外键约束以同表的 SQL 约束行完整列出；类型中的长度不是字符显示宽度。主键（Primary Key）标识实体，外键（Foreign Key）约束引用完整性。

teams

字段	类型	约束 / 默认值
id	INT UNSIGNED	AUTO_INCREMENT PRIMARY KEY
name	VARCHAR(100)	NOT NULL
tagline	VARCHAR(255)	NOT NULL DEFAULT ''
description	TEXT	NOT NULL
email	VARCHAR(254)	NOT NULL DEFAULT ''
location	VARCHAR(120)	NOT NULL DEFAULT ''
updated_at	TIMESTAMP	NOT NULL DEFAULT CURRENT_TIMESTAMP ON UPDATE CURRENT_TIMESTAMP

members

字段	类型	约束 / 默认值
id	INT UNSIGNED	AUTO_INCREMENT PRIMARY KEY
name	VARCHAR(100)	NOT NULL
title	VARCHAR(120)	NOT NULL DEFAULT ''
bio	TEXT	NOT NULL
email	VARCHAR(254)	NOT NULL DEFAULT ''
avatar_color	VARCHAR(16)	NOT NULL DEFAULT '#6554c0'
sort_order	INT	NOT NULL DEFAULT 0
created_at	TIMESTAMP	NOT NULL DEFAULT CURRENT_TIMESTAMP
updated_at	TIMESTAMP	NOT NULL DEFAULT CURRENT_TIMESTAMP ON UPDATE CURRENT_TIMESTAMP

users

字段	类型	约束 / 默认值
id	INT UNSIGNED	AUTO_INCREMENT PRIMARY KEY
username	VARCHAR(64)	NOT NULL UNIQUE
password_hash	VARCHAR(255)	NOT NULL
role	ENUM('admin','member')	NOT NULL DEFAULT 'member'
member_id	INT UNSIGNED	NULL UNIQUE
enabled	BOOLEAN	NOT NULL DEFAULT TRUE
created_at	TIMESTAMP	NOT NULL DEFAULT CURRENT_TIMESTAMP

CONSTRAINT fk_users_member FOREIGN KEY (member_id) REFERENCES members(id) ON DELETE SET NULL

skills

字段	类型	约束 / 默认值
id	INT UNSIGNED	AUTO_INCREMENT PRIMARY KEY
name	VARCHAR(100)	NOT NULL UNIQUE

member_skills

字段	类型	约束 / 默认值
member_id	INT UNSIGNED	NOT NULL
skill_id	INT UNSIGNED	NOT NULL
level	TINYINT UNSIGNED	NOT NULL DEFAULT 1

PRIMARY KEY (member_id, skill_id)

CONSTRAINT chk_member_skill_level CHECK (level BETWEEN 1 AND 5)

CONSTRAINT fk_member_skills_member FOREIGN KEY (member_id) REFERENCES members(id) ON DELETE CASCADE

CONSTRAINT fk_member_skills_skill FOREIGN KEY (skill_id) REFERENCES skills(id) ON DELETE CASCADE

projects

字段	类型	约束 / 默认值
id	INT UNSIGNED	AUTO_INCREMENT PRIMARY KEY
team_id	INT UNSIGNED	NOT NULL DEFAULT 1
title	VARCHAR(200)	NOT NULL
summary	VARCHAR(500)	NOT NULL DEFAULT ''
description	TEXT	NOT NULL
status	ENUM('planning','active','completed')	NOT NULL DEFAULT 'planning'
published	BOOLEAN	NOT NULL DEFAULT FALSE
progress	TINYINT UNSIGNED	NOT NULL DEFAULT 0
started_on	DATE	NULL
created_at	TIMESTAMP	NOT NULL DEFAULT CURRENT_TIMESTAMP
updated_at	TIMESTAMP	NOT NULL DEFAULT CURRENT_TIMESTAMP ON UPDATE CURRENT_TIMESTAMP

INDEX idx_projects_public (published,status,id)

CONSTRAINT chk_projects_progress CHECK (progress BETWEEN 0 AND 100)

CONSTRAINT fk_projects_team FOREIGN KEY (team_id) REFERENCES teams(id) ON DELETE RESTRICT

project_members

字段	类型	约束 / 默认值
project_id	INT UNSIGNED	NOT NULL
member_id	INT UNSIGNED	NOT NULL
role	VARCHAR(120)	NOT NULL DEFAULT '贡献者'

PRIMARY KEY (project_id,member_id)

CONSTRAINT fk_project_members_project FOREIGN KEY (project_id) REFERENCES projects(id) ON DELETE CASCADE

CONSTRAINT fk_project_members_member FOREIGN KEY (member_id) REFERENCES members(id) ON DELETE CASCADE

updates

字段	类型	约束 / 默认值
id	INT UNSIGNED	AUTO_INCREMENT PRIMARY KEY
project_id	INT UNSIGNED	NULL
author_id	INT UNSIGNED	NOT NULL
title	VARCHAR(200)	NOT NULL
body	TEXT	NOT NULL
published	BOOLEAN	NOT NULL DEFAULT FALSE
published_at	DATETIME	NULL
created_at	TIMESTAMP	NOT NULL DEFAULT CURRENT_TIMESTAMP
updated_at	TIMESTAMP	NOT NULL DEFAULT CURRENT_TIMESTAMP ON UPDATE CURRENT_TIMESTAMP

INDEX idx_updates_public (published,published_at,id)

CONSTRAINT fk_updates_project FOREIGN KEY (project_id) REFERENCES projects(id) ON DELETE SET NULL

CONSTRAINT fk_updates_author FOREIGN KEY (author_id) REFERENCES users(id) ON DELETE RESTRICT

messages

字段	类型	约束 / 默认值
id	INT UNSIGNED	AUTO_INCREMENT PRIMARY KEY
name	VARCHAR(100)	NOT NULL
email	VARCHAR(254)	NOT NULL DEFAULT ''
body	TEXT	NOT NULL
status	ENUM('pending','approved','rejected')	NOT NULL DEFAULT 'pending'
created_at	TIMESTAMP	NOT NULL DEFAULT CURRENT_TIMESTAMP
updated_at	TIMESTAMP	NOT NULL DEFAULT CURRENT_TIMESTAMP ON UPDATE CURRENT_TIMESTAMP

INDEX idx_messages_status (status,created_at,id)

message_replies

字段	类型	约束 / 默认值
id	INT UNSIGNED	AUTO_INCREMENT PRIMARY KEY
message_id	INT UNSIGNED	NOT NULL
body	TEXT	NOT NULL
author_id	INT UNSIGNED	NOT NULL
created_at	TIMESTAMP	NOT NULL DEFAULT CURRENT_TIMESTAMP

CONSTRAINT fk_message_replies_message FOREIGN KEY (message_id) REFERENCES messages(id) ON DELETE CASCADE

CONSTRAINT fk_message_replies_author FOREIGN KEY (author_id) REFERENCES users(id) ON DELETE RESTRICT

milestones

字段	类型	约束 / 默认值
id	INT UNSIGNED	AUTO_INCREMENT PRIMARY KEY
project_id	INT UNSIGNED	NOT NULL
title	VARCHAR(200)	NOT NULL
due_on	DATE	NULL
completed	BOOLEAN	NOT NULL DEFAULT FALSE

CONSTRAINT fk_milestones_project FOREIGN KEY (project_id) REFERENCES projects(id) ON DELETE CASCADE

submissions

字段	类型	约束 / 默认值
id	INT UNSIGNED	AUTO_INCREMENT PRIMARY KEY
title	VARCHAR(200)	NOT NULL
kind	VARCHAR(64)	NOT NULL UNIQUE
file_name	VARCHAR(255)	NOT NULL UNIQUE
description	VARCHAR(500)	NOT NULL DEFAULT ''
sort_order	INT	NOT NULL DEFAULT 0

audit_logs

字段	类型	约束 / 默认值
id	INT UNSIGNED	AUTO_INCREMENT PRIMARY KEY
user_id	INT UNSIGNED	NULL
action	VARCHAR(100)	NOT NULL
entity_type	VARCHAR(64)	NOT NULL
entity_id	INT UNSIGNED	NULL
created_at	TIMESTAMP	NOT NULL DEFAULT CURRENT_TIMESTAMP

INDEX idx_audit_entity (entity_type,entity_id)

INDEX idx_audit_created (created_at)

CONSTRAINT fk_audit_user FOREIGN KEY (user_id) REFERENCES users(id) ON DELETE SET NULL

login_attempts

字段	类型	约束 / 默认值
id	INT UNSIGNED	AUTO_INCREMENT PRIMARY KEY
ip_hash	CHAR(64)	NOT NULL
created_at	TIMESTAMP	NOT NULL DEFAULT CURRENT_TIMESTAMP

INDEX idx_login_attempts_ip_time (ip_hash,created_at)

INDEX idx_login_attempts_time (created_at)

6. 查询、安全与实现映射

详情通过主键查询；成员技能、项目成员通过关联表查询；公开留言强制增加审核状态条件。所有用户可见文本经 Html::encode 或等价转义，阻止跨站脚本（Cross-Site Scripting, XSS）。数据库参数绑定不替代输出转义，二者保护不同边界。

本地演示保留 PHP 会话（Session）与 CSRF 默认保护。会话位于临时目录，容器重建后重新登录是预期行为；业务数据位于 MySQL 卷，不能因会话清除而丢失。

参考：Yii2 Security Best Practices，https://www.yiiframework.com/doc/guide/2.0/en/security-best-practices 。该设计选择来自成熟框架机制，不采用自创加密或自制认证协议。